

SIMATS ENGINEERING

ASSESSMENT TOOL 1

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO3: *Assess incident identification processes using monitoring systems, log analysis, threat intelligence, detection mechanisms to verify incidents, classify threats, assess their impact. (BL2, BL3)*

Activity Tool : Log Analysis and Incident Identification (High)

Assessment Tool Weightage: 40%

Code of Conduct:

I ____shaikreehan192565071____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Log Analysis and Identification of Suspicious Activities	25%	Thoroughly analyzes relevant system, network, authentication, application, and security logs and accurately identifies suspicious activities and attack patterns.	Analyzes most relevant logs and identifies major suspicious activities with minor omissions.	Performs basic log analysis but misses important events or patterns.	Unable to analyze logs or identify relevant suspicious activities.
IOC Identification and Detection Sources	20%	Accurately identifies and validates relevant IOCs and effectively uses network, host, and application detection sources to support the investigation.	Identifies most relevant IOCs and detection sources with minor gaps.	Identifies limited IOCs or detection sources with insufficient analysis.	Unable to identify relevant IOCs or appropriate detection sources.
Event Correlation and Incident Verification	20%	Effectively correlates events from multiple sources and clearly verifies whether the activity represents a true incident or false positive using appropriate evidence.	Correctly correlates and verifies most events with minor omissions.	Provides limited correlation and incomplete incident verification.	Unable to correlate events or verify the incident.
Incident Classification, Prioritization, and Impact Assessment	20%	Accurately classifies and prioritizes the incident based on severity, asset criticality, affected users, data sensitivity, and business impact, with clear justification.	Correctly classifies and prioritizes the incident with reasonable impact assessment and minor gaps.	Provides basic classification and prioritization with limited impact analysis.	Unable to appropriately classify, prioritize, or assess the impact of the incident.
Documentation, Analysis, and Presentation	15%	Provides clear, professional documentation with logical analysis, evidence, incident timeline, conclusions, and appropriate diagrams or workflows.	Documentation is well organized and understandable with minor presentation or analytical issues.	Documentation is partially organized with limited evidence or analytical clarity.	Documentation is incomplete, poorly organized, and lacks supporting evidence or clear conclusions.

1. SIEM-Based Incident Identification

Introduction

A Security Information and Event Management (SIEM) system is a centralized security platform that collects, normalizes, analyzes, and correlates security events from multiple sources such as firewalls, servers, endpoints, applications, authentication systems, IDS/IPS, and network devices.

The main purpose of SIEM is to identify suspicious activities by combining individual events into a meaningful security incident.

SIEM Incident Identification Process

Log Sources → Collection → Normalization → Correlation → IOC Detection → Alert → Incident Verification → Classification & Prioritization → Response

1. Log Collection and Analysis

The SIEM collects logs from different sources.

Log Source	Important Events
Firewall	Allowed/blocked connections, unusual IP addresses
Authentication	Failed/successful logins, privilege changes
Servers	Process execution, file access, system changes
Endpoints	Malware alerts, suspicious processes
Applications	Errors, abnormal requests, unauthorized access
IDS/IPS	Port scans, exploits, malicious traffic
Network devices	Unusual connections and traffic patterns

For example, the SIEM may detect:

- 500 failed login attempts from one IP.
- A successful login immediately after the failures.
- The account accessing a sensitive server.
- An unusual executable being launched.
- Large amounts of data being transferred.

Individually, these events may appear unrelated. SIEM **correlates them to identify a possible account-compromise incident.**

2. IOC Identification

An **Indicator of Compromise (IOC)** is evidence that may indicate a security breach.

Common IOCs include:

- Malicious IP addresses
- Suspicious domains
- Malicious URLs
- File hashes
- Unusual usernames
- Suspicious processes
- Abnormal network connections
- Repeated authentication failures
- Unexpected privilege escalation

- Unusual file modifications

Detection Sources

SIEM can obtain IOC evidence from:

Network: Firewall, IDS/IPS, DNS, proxy and network-flow logs.

Host: Antivirus/EDR, operating-system logs and process activity.

Application: Application access logs, database logs and API logs.

Authentication: Active Directory, VPN, SSH and authentication-server logs.

3. Event Correlation and Incident Verification

SIEM uses **correlation rules** to connect events from different sources.

Example

Suppose the following events occur:

10:01 AM: 300 failed logins from 192.168.X.X

↓

10:04 AM: Successful login using the targeted account

↓

10:05 AM: Login originates from an unusual location/device

↓

10:07 AM: Privileged account accessed

↓

10:10 AM: Large data transfer detected

The SIEM correlates these events and identifies a possible **credential-compromise and data-exfiltration incident**.

The analyst then verifies whether it is a **true positive or false positive** by examining:

- User identity
- Source IP
- Device information
- Authentication history
- Endpoint activity
- Network connections
- File-access logs
- Data-transfer records

This prevents security teams from responding unnecessarily to legitimate activity.

4. Incident Classification and Prioritization

After verification, the incident should be classified according to its nature and severity.

Example:

Incident: Compromised privileged account

Classification: Account compromise / unauthorized access

Severity: High/Critical

Factors used for prioritization

- **Asset criticality:** Is a production or sensitive server affected?

- **User privileges:** Is the account administrative?
- **Data sensitivity:** Is confidential information involved?
- **Number of affected systems:** One endpoint or the entire network?
- **Business impact:** Could operations be interrupted?
- **Attack progression:** Is the attacker still active?
- **Data exfiltration:** Has sensitive information potentially been stolen?

A compromised administrator account accessing a critical database would receive a much higher priority than a suspicious event involving a non-critical test machine.

5. Documentation and Incident Timeline

The security team should document the incident chronologically.

Time	Event	Source	Significance
10:01	Multiple failed logins	Authentication	Possible brute-force attack
10:04	Successful login	Authentication	Possible account compromise
10:05	Unusual device login	VPN/Authentication	Suspicious source
10:07	Privileged access	Server	Possible privilege misuse
10:10	Large data transfer	Network	Possible exfiltration

This timeline helps investigators understand the **attack progression, affected assets, IOCs, and evidence**.

Major Functions of SIEM

1. Log collection
2. Log aggregation
3. Log normalization
4. Real-time monitoring
5. Event correlation
6. IOC detection
7. Threat intelligence integration
8. Alert generation
9. Incident investigation
10. Incident timeline creation
11. Compliance reporting
12. Security dashboards
13. Historical analysis and forensics

Benefits

- Centralized security visibility
- Faster incident detection
- Better event correlation
- Improved incident investigation
- Reduced response time
- Detection of attacks across multiple systems
- Improved forensic analysis

- Better compliance and auditing
- More effective incident prioritization

Conclusion

SIEM acts as the **central intelligence layer of security monitoring**. It does not simply collect logs; it combines evidence from different sources, identifies IOCs, correlates related events, verifies incidents, and helps analysts classify and prioritize threats.

2. IDS/IPS and Security Monitoring

Introduction

An **Intrusion Detection System (IDS)** monitors network or system activity and generates alerts when suspicious behavior is detected.

An **Intrusion Prevention System (IPS)** performs similar detection but can also **automatically block or prevent malicious activity**.

For an organization experiencing **port scans, suspicious network connections, and possible malware traffic**, IDS/IPS can provide continuous detection and prevention.

1. Detection of Port Scanning

A port scan is commonly used during the **reconnaissance phase** of an attack.

For example:

Attacker → Port 21 → Port 22 → Port 80 → Port 443 → Port 3389

An IDS can identify:

- Large numbers of connection attempts
- Connections to sequential ports
- Connections to multiple hosts
- Repeated connection attempts from one source IP
- Unusual scanning patterns

The IDS generates an alert such as:

"Possible TCP Port Scan Detected."

An IPS can go further and:

- Drop malicious packets
 - Block the source IP
 - Terminate suspicious connections
 - Apply a firewall rule
-

2. Detection of Suspicious Network Connections

IDS/IPS can inspect network traffic for unusual communication patterns.

Examples include:

- Internal systems communicating with unknown external IPs
- Connections to known malicious domains
- Unusual destination ports
- Repeated outbound connections
- Unexpected protocols
- Communication at unusual times

These events can be correlated with firewall and DNS logs in a SIEM.

3. Malware Traffic Detection

IDS/IPS can detect known malware communication using:

Signature-Based Detection

The system compares network traffic against known attack or malware signatures.

Example:

Endpoint → Known malicious C2 server

The IDS detects the known signature and generates an alert.

An IPS can block the connection.

Anomaly-Based Detection

The system identifies traffic that differs significantly from normal behavior.

Example:

A workstation normally communicates with five internal services but suddenly begins sending thousands of requests to an unfamiliar external server.

This could indicate **malware or command-and-control (C2) activity**.

Behavior-Based Detection

The system looks for suspicious patterns rather than relying only on known signatures.

For example:

Infected Host → DNS request → External connection → Periodic communication → Data transfer

This pattern may indicate malware attempting to communicate with its command-and-control infrastructure.

4. IOC Identification

IDS/IPS can provide valuable IOCs such as:

- Source IP address
- Destination IP address
- Destination port
- Malicious domain
- URL
- Packet characteristics
- Malware signature
- Suspicious protocol
- Connection frequency
- Network behavior

These IOCs can then be forwarded to the **SIEM** for correlation with endpoint, authentication, server, and firewall logs.

5. Event Correlation

Consider this scenario:

Event 1

IDS detects a port scan from an external IP.

Event 2

Firewall records repeated connection attempts from the same IP.

Event 3

IPS detects an exploit attempt against a web server.

Event 4

Endpoint security detects a suspicious process on the web server.

Event 5

The server begins communicating with an external suspicious IP.

The SIEM can correlate all five events.

Instead of treating them as separate alerts, the security team can identify a possible attack chain:

Reconnaissance → Exploitation → Compromise → Malware/C2 Communication

This provides much stronger evidence of a **true security incident**.

6. Incident Classification and Prioritization

The incident can be classified as:

Incident Type: Network intrusion / malware infection

Severity: High or Critical

The severity depends on:

- Criticality of the affected server
- Whether the attacker successfully exploited the system
- Whether malware was installed
- Whether sensitive data was accessed
- Number of affected systems
- Whether command-and-control communication is occurring
- Potential business impact

For example, a port scan against a public test server may be **Low/Medium severity**, while a successful exploit followed by malware communication from a critical database server could be **Critical severity**.

IDS vs IPS

Feature	IDS	IPS
Full form	Intrusion Detection System	Intrusion Prevention System
Main function	Detects attacks	Detects and prevents attacks
Action	Generates alert	Blocks/drops traffic
Deployment	Usually passive	Usually inline
Port scan	Detects and alerts	Detects and can block
Malware traffic	Detects suspicious traffic	Can block malicious traffic
Advantage	Good visibility	Real-time prevention
Limitation	Does not normally stop attacks	Incorrect blocking can affect legitimate traffic

Detection Methods

Method	Description	Advantage	Limitation
Signature-based	Matches known attack patterns	Excellent for known attacks	Cannot easily detect new attacks
Anomaly-based	Detects deviations from normal behavior	Can detect unknown threats	May create false positives
Behavior-based	Identifies suspicious activity patterns	Useful for sophisticated attacks	Requires accurate behavioral models

Advantages of IDS/IPS

- Continuous network monitoring
- Early attack detection
- Port-scan detection
- Malware detection
- Exploit detection
- Identification of suspicious connections
- Automatic blocking with IPS
- Generation of useful IOCs
- Supports incident investigation
- Provides evidence for SIEM correlation

Limitations

- False positives
 - False negatives
 - Encrypted traffic can be difficult to inspect
 - Signature-based detection may miss zero-day attacks
 - High network traffic can increase processing requirements
 - Incorrect IPS rules can block legitimate traffic
 - Attackers may use evasion techniques
 - Requires regular rule/signature updates
-

Integrated SIEM + IDS/IPS Workflow

The strongest security-monitoring architecture combines both technologies:

Network Traffic

↓

IDS/IPS

↓

Detect / Block Suspicious Activity

↓

SIEM

↓

Collect Firewall + Authentication + Endpoint + Server Logs

↓

IOC Identification



Event Correlation



Incident Verification



Classification & Prioritization



Incident Response

Final Conclusion

IDS/IPS provides detection and prevention at the network/system level, while SIEM provides centralized correlation and investigation. When combined, they enable an organization to identify IOCs, correlate events from multiple sources, verify true incidents, assess their impact, prioritize response, and maintain a complete incident timeline.

This directly addresses all five rubric areas: **log analysis (25%), IOC identification (20%), event correlation (20%), incident classification/impact (20%), and documentation/presentation (15%).**